



Name: _____ Cohort/Batch: _____ Date: _____ Score: _____

SAML PRACTICE SHEET - 10 CONCEPTUAL Q&A

10 conceptual Q&A Security

TOTAL: 10 QUESTIONS

Q1 What is SAML and what security threat does it address?

Threat Model

Q6 How do you audit and monitor SAML events?

Observability

Q2 What is the core mechanism SAML uses to provide security?

Architecture

Q7 How does SAML handle key or credential rotation?

Lifecycle

Q3 How do you configure SAML for a production web application?

Configuration

Q8 How does SAML help meet compliance requirements?

Compliance

Q4 What are the most common SAML misconfigurations to avoid?

Hardening

Q9 How do you test your SAML configuration for weaknesses?

Testing

Q5 How does SAML integrate with identity providers?

SSO / IdP

Q10 What are the performance implications of SAML and how do you minimize them?

Tuning



ANSWER KEY & EXPLANATORY SOLUTIONS

Comprehensive verified answers, best-practice configs, security controls & reference

VERIFIED SOLUTIONS

A1 SAML is a security tool, protocol,

Mitigation

SAML is a security tool, protocol, or service that mitigates a specific class of threats authentication bypass, data exfiltration, network intrusion, or credential theft. Understanding the threat model is prerequisite to correct configuration.

A6 Enable SAML's audit log and stream

Observability

Enable SAML's audit log and stream it to a SIEM (Splunk, Elastic SIEM). Define alert rules for high-severity events: repeated failed logins, privilege escalation, and unusual access patterns. Review logs regularly.

A2 SAML uses one or more security

Primitives

SAML uses one or more security primitives: asymmetric cryptography, symmetric encryption, certificate chains, role-based access control, or anomaly detection. These primitives are combined to provide the claimed security properties.

A7 Automate rotation using a secrets manager

Automation

Automate rotation using a secrets manager that generates new credentials and updates consumers transparently. Test rotation in staging. Have a break-glass procedure for emergency rotation when a credential is compromised.

A3 Production configuration requires strong cipher

Hardening

Production configuration requires strong cipher suites, certificate rotation, revocation checking, and minimal permission grants. Use a well-reviewed configuration reference (CIS Benchmark, OWASP) rather than default settings.

A8 SAML generates audit trails, enforces access

Governance

SAML generates audit trails, enforces access policies, and provides encryption that satisfy controls required by SOC 2, PCI-DSS, HIPAA, and GDPR. Map SAML's capabilities to the specific framework controls in your compliance program.

A4 Common mistakes include using outdated

Gotchas

Common mistakes include using outdated algorithms (MD5, SHA1, RC4), leaving default credentials, ignoring certificate expiry, granting excessive permissions, and not testing the config before going live in production.

A9 Run an automated scanner (SSL Labs)

Assessment

Run an automated scanner (SSL Labs for TLS, ScoutSuite for cloud IAM, OWASP ZAP for web app auth) against your SAML config. Conduct penetration tests annually and after significant config changes.

A5 SAML delegates identity verification to an

Federation

SAML delegates identity verification to an IdP via SAML, OIDC, or LDAP. Users authenticate once (SSO) and receive a token that SAML validates. This centralizes user management and avoids duplicating auth logic across services.

A10 Cryptographic operations, token validation, and

Optimization

Cryptographic operations, token validation, and authorization checks add latency. Mitigate with session caching, hardware-accelerated TLS (AES-NI), connection reuse, and async authorization where possible.